



Software Verification and Validation

SUBMITTED TO:

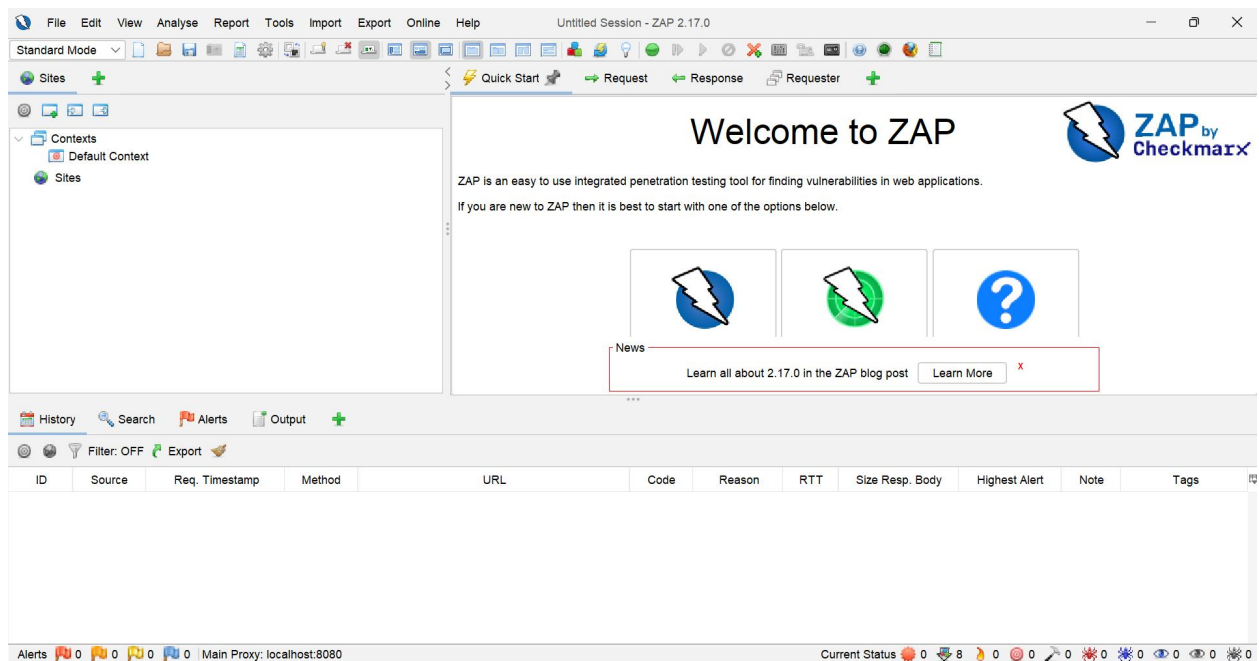
Ma'am Jawairia Ramzan

SUBMITTED BY:

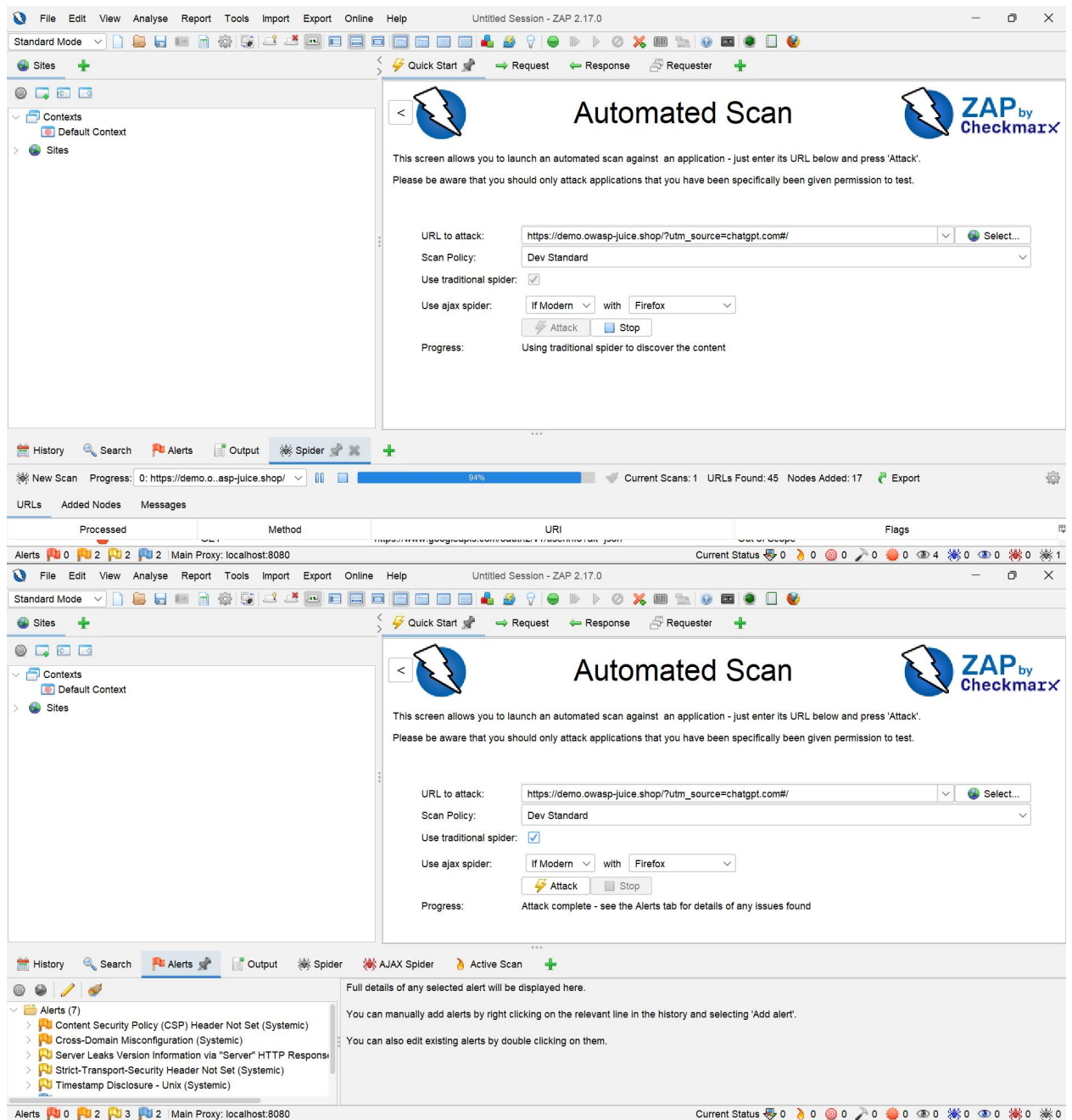
MUHAMMAD Fahad
FALL-23 080 BSSE (B)

**DEPARTMENT OF SOFTWARE
ENGINEERING**

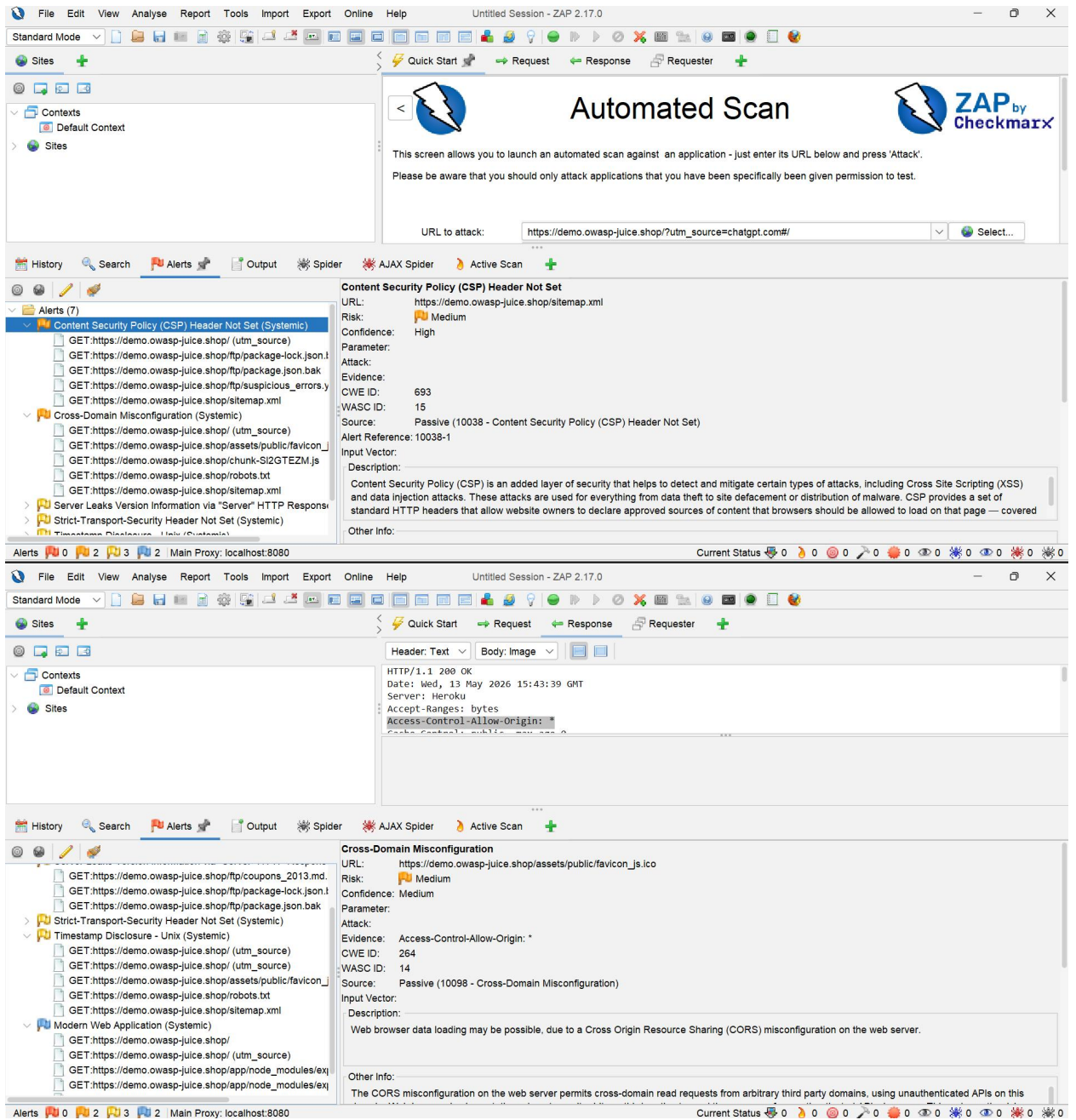
Task 1 — Install and Configure OWASP ZAP



Task 2 — Run Automated Security Scan



Task 3 — Identify Vulnerabilities



Vulnerability	Severity	Affected Page	Description
Content Security Policy (CSP) Header Not Set	Medium	/sitemap.xml	No CSP header set, leaving the site open to XSS and data injection attacks

Cross-Domain Misconfiguration	Medium	/assets/public/favicon_js.ico	CORS misconfiguration allows any domain to read data from this site
Server Leaks Version Info via "Server" HTTP Response	Low	/ftp/package-lock.json	Server header reveals it is running on Heroku, exposing infrastructure info
Strict-Transport-Security Header Not Set	Low	/	HTTPS is not enforced, allowing possible downgrade attacks
Timestamp Disclosure - Unix	Informational	/robots.txt	Server reveals internal Unix timestamps in responses
Modern Web Application	Informational	/	Site uses modern JS framework which may have client-side vulnerabilities

Task 4 — Recommend Security Improvements

Vulnerability	Recommendation
Content Security Policy (CSP) Header Not Set	Add a Content-Security-Policy HTTP header to define trusted content sources and block malicious scripts
Cross-Domain Misconfiguration	Replace Access-Control-Allow-Origin: * with specific trusted domains only
Server Leaks Version Info via "Server" HTTP Response	Configure the server to remove or hide the Server header in HTTP responses

Strict-Transport-Security Header Not Set	Add Strict-Transport-Security header to force browsers to use HTTPS only
Timestamp Disclosure - Unix	Disable timestamp exposure in server responses to prevent information leakage
Modern Web Application	Keep JavaScript frameworks updated and apply client-side input validation

Task 5 — Validation Reflection

Q1: Why is security validation important?

Security validation is important because it identifies vulnerabilities before attackers exploit them, protects sensitive user data, and ensures the application meets security standards.

Q2: What is the difference between functional correctness and security correctness?

Functional correctness means the application works as intended. Security correctness means it is safe from attacks. An application can be functionally correct but still be insecure.

Q3: How does OWASP ZAP help validation engineers?

OWASP ZAP automatically scans web applications for vulnerabilities, analyzes HTTP traffic, generates alerts with risk levels, and produces reports as validation evidence — saving time compared to manual testing.